CYBERSECURITY INTERNSHIP

WEEK 8 ASSIGNMENT

ADVANCED VAPT: ATTACK CHAIN & FULL EXPLOITATION PROJECT

Submitted by	Deepashree C.
Role	Cybersecurity Intern
Week	Week 8
SIN	DG/SEPTEMBER/CYBER/254
Submitted to	DG Interns Hub

Target: Damn Vulnerable Web Application (DVWA) — Security Level: Medium

Testing environment: Isolated virtual lab using Kali Linux, Firefox and Burp Suite Community Edition

1. Executive Summary

This report documents an authorized web application security assessment of Damn Vulnerable Web Application (DVWA) at Medium security level in an isolated virtual lab. The assessment used Kali Linux, Mozilla Firefox and Burp Suite Community Edition. Testing focused on the attack surface, authentication workflow, authorization enforcement, HTTP parameter handling and session management.

The main observation was that a restricted page displayed an “Unauthorised” message to a non-administrative test account, while a backend endpoint inspected during testing returned multiple user records, including administrator information. This suggests a possible server-side access-control weakness and potential unauthorized data disclosure. The presentation also records numeric session ID values that appeared related to generation time; predictability was not confirmed. A User ID parameter was changed in Burp Suite Repeater, but unauthorized object access was not confirmed.

The findings indicate a need to enforce authorization on every sensitive backend endpoint, use secure unpredictable session identifiers, validate user-controlled parameters, and test APIs independently. Administrative access and account takeover were not demonstrated. Findings should be treated according to the evidence recorded and revalidated after fixes.

Assessment Snapshot

Target	Damn Vulnerable Web Application (DVWA)
Security level	Medium
Environment	Isolated virtual lab
Tools	Kali Linux, Mozilla Firefox, Burp Suite Community Edition
Primary observation	Possible backend authorization weakness exposing user records
Other observations	Potential session ID predictability; parameter tampering tested, IDOR not confirmed
Scope limitation	Authorized local lab only; no claim of account takeover or admin control

2. Introduction and Objectives

2.1 Introduction

Vulnerability Assessment and Penetration Testing (VAPT) helps identify weaknesses in an application and understand their potential effect. Instead of reviewing each issue in isolation, attack-chain analysis examines how an attacker might combine weaknesses to reach sensitive information or functionality. This assessment was performed only against the intentionally vulnerable DVWA application in a controlled lab.

2.2 Objectives

- Identify the application attack surface and important entry points.
- Review the login workflow and HTTP request-response behavior.
- Check whether authorization controls protect restricted pages and backend endpoints.
- Use Burp Suite to capture, inspect and modify selected HTTP requests.
- Observe session identifier characteristics without claiming unverified exploitability.
- Document a potential attack chain, assess business impact and recommend remediation.

2.3 Scope and Rules of Engagement

The scope was limited to DVWA in an isolated virtual lab at Medium security level. Testing was manual and focused on the modules described in the presentation. No production system was targeted. Automated password guessing was not performed. Results in this report reflect the observations stated in the presentation; where evidence is incomplete, the finding is marked as potential or requiring further validation.

3. Target, Scope and Environment

Target application	Damn Vulnerable Web Application (DVWA)
Target address	10.x.x.x (local lab IP; exact address not provided)
Operating platform	Kali Linux
Browser	Mozilla Firefox
Proxy/testing tool	Burp Suite Community Edition
DVWA security level	Medium
Testing type	Authorized local web application VAPT
Network boundary	Isolated virtual lab

3.1 Tools Used

- Kali Linux — testing operating system in the lab.
- Mozilla Firefox — interacting with the DVWA web interface.
- Burp Suite Community Edition — intercepting and inspecting HTTP requests, and replaying selected requests with Repeater.

3.2 Limitations

- The presentation uses a masked target IP (10.x.x.x); the exact local address is not available.
- Screenshots are referenced in the presentation, but their full underlying request and response contents are not reproduced in this report.
- The session identifier observation requires additional testing before predictability can be confirmed.
- Changing a User ID parameter alone does not prove IDOR; access to another user's protected object must be confirmed.
- The recorded chain demonstrates potential unauthorized information exposure, not account takeover or administrative control.

4. Attack Surface Mapping

The following entry points were identified for manual review, based on the modules and activities described in the presentation.

Entry point / module	What was checked	Purpose
Login module	Authentication workflow and login request parameters	Understand authentication behavior and request structure
Access-control / restricted page	Attempted access as non-admin user	Check whether restricted functionality is protected
Backend endpoint	Response inspected through Burp Suite	Determine whether server-side authorization protects user records
SQL Injection module input	User ID parameter modified using Repeater	Observe how the application handles changed parameter values
Brute Force module	Login request intercepted; no automated guessing	Review authentication request and protection behavior
Session handling	Numeric session ID values observed	Identify whether identifiers may need stronger randomness

4.1 Application Flow (Observed)

1. The tester opens DVWA in Firefox and signs in with the authorized test account gordonb.
2. The tester navigates to the relevant module or restricted page.
3. Burp Suite intercepts or records the request for inspection.
4. Selected parameters or backend endpoints are examined in a controlled manner.
5. The server response is reviewed to determine whether access restrictions are consistently enforced.

Note: The presentation does not provide a complete site map or a list of every API route. This section therefore records the tested entry points rather than claiming exhaustive discovery.

5. Testing Methodology and Procedure

5.1 Authentication Testing

6. Logged in with the authorized non-administrative test account gordonb.
7. Intercepted the login request using Burp Suite.
8. Reviewed the HTTP method and authentication-related parameters.
9. Kept testing manual; automated password guessing was not performed.

Result: The login request was inspected. The presentation does not report a confirmed authentication bypass.

5.2 Parameter Tampering

10. Opened the SQL Injection module in DVWA.
11. Intercepted the relevant request in Burp Suite.
12. Sent the request to Repeater and modified the User ID parameter.
13. Resubmitted the request and reviewed the server response.

Result: Parameter manipulation was tested. The presentation explicitly does not claim a confirmed IDOR vulnerability. Confirmation would require evidence that a user can access another user's protected object without permission.

5.3 Authorization Bypass Testing

14. Used the non-admin gordonb account.
15. Attempted to open the restricted Authorization Bypass page.
16. Observed an "Unauthorised" message on the page.
17. Inspected the related backend endpoint using Burp Suite.
18. Observed a response containing multiple user records, including administrator information.

Result: The difference between the page-level denial and the backend response suggests authorization may not be enforced consistently on the backend endpoint.

5.4 Session Management Observation

The presentation notes numeric session ID values that appeared related to generation time. This is a signal for further testing, not proof that the IDs are predictable or that session hijacking is possible. A safe follow-up should compare multiple identifiers in the lab, check randomness and length, and verify that identifiers change after authentication.

6. Attack Chain Development

The chain below is limited to the behavior described in the presentation. It illustrates a possible information-disclosure path rather than a demonstrated account takeover.

Step 1 — Establish a normal user session

Sign in to DVWA using the authorized non-administrative gordonb test account.

Step 2 — Request restricted functionality

Navigate to the restricted Authorization Bypass page. The interface displays “Unauthorised”.

Step 3 — Inspect the backend request

Use Burp Suite to inspect the backend endpoint associated with the feature.

Step 4 — Review the response

The endpoint response is observed to contain multiple user records, including administrator information.

Step 5 — Assess the security gap

The backend response suggests that endpoint-level authorization may be missing or incorrectly applied, despite the front-end restriction.

6.1 Attack Flow Diagram

Non-admin user: gordonb
↓
Restricted page displays “Unauthorised”
↓
Backend endpoint inspected with Burp Suite
↓
Response contains multiple user records
↓
Potential impact: unauthorized user-information disclosure

Figure 1. Attack flow reconstructed from the observations described in the presentation.

6.2 Chain Impact and Boundaries

The observed behavior indicates a possible path to unauthorized information disclosure. It shows why front-end restrictions alone are insufficient when a backend endpoint does not independently verify the caller’s permissions. The presentation does not demonstrate account takeover, privilege escalation to administrator, or control of the application; those outcomes must not be claimed.

7. Findings and Risk Assessment

Finding 1: Possible Improper Authorization on Backend Endpoint

Severity recorded in presentation: HIGH

Evidence: A non-admin user received an “Unauthorised” message from the restricted page, but the inspected backend endpoint returned multiple user records, including administrator information.

Potential impact: Unauthorized disclosure of user information, privacy risks, and information that could support targeted attacks.

Confidence / caveat: The presentation records the observed response but does not include full raw HTTP evidence in its text. Confirm the exact endpoint, data fields, authentication state and repeatability before final severity assignment.

Finding 2: Potential Weak Session ID Generation

Severity recorded in presentation: MEDIUM

Evidence: Session IDs were described as numeric and apparently related to generation time.

Potential impact: If identifiers are predictable, an attacker might be able to guess or infer a valid session token. This could lead to session compromise.

Caveat: Predictability and session hijacking were not demonstrated. More samples and appropriate randomness analysis are required.

Finding 3: Potential IDOR / Parameter-Based Access Issue

Severity recorded in presentation: MEDIUM

Evidence: The User ID parameter was modified using Burp Suite Repeater.

Potential impact: If the server trusts a user-controlled object identifier without checking ownership, one user might access another user’s data.

Caveat: Unauthorized object access was not confirmed. Treat this as an unverified lead, not a proven vulnerability.

7.1 Business Impact

- Confidentiality: personal or account-related information may be disclosed to users without permission.
- Privacy and trust: affected users may lose confidence in the application or service.
- Targeting risk: exposed user details could help attackers craft more convincing follow-on attacks.
- Compliance: depending on the data and jurisdiction, unauthorized disclosure may create reporting or regulatory concerns.
- Operational impact: incident response, investigation and remediation may consume staff time and resources.

8. Proof of Concept (POC) and Evidence

The following POC summary is based on the steps recorded in the supplied presentation. It is not a substitute for attaching the original screenshots and sanitized request/response evidence.

Evidence item	What it should demonstrate	Status in source presentation
Figure 2 — Login request in Burp Suite	Login HTTP request and authentication parameters	Referenced in presentation
Figure 3 — Modified User ID parameter	Original and modified parameter in Repeater	Referenced in presentation
Figure 4 — Restricted page	“Unauthorised” message when using gordonb	Referenced in presentation
Figure 5 — Backend JSON response	Response containing multiple user records	Referenced in presentation
Figure 6 — Attack flow	Sequence from non-admin session to possible data exposure	Referenced in presentation
Figure 7 — Session ID values	Numeric session values observed during testing	Referenced in presentation

8.1 Suggested Evidence Notes

- Capture the request and response with sensitive values masked where appropriate.
- Record the account role, application security level, endpoint and test time.
- For authorization testing, compare what a normal user can request with the permissions that should apply.
- For IDOR validation, use only lab-owned test accounts and harmless test records, and show whether access was actually denied or allowed.
- Do not include real passwords, active session tokens or unnecessary personal information in the report.

9. Remediation Strategy

9.1 Fix the Backend Authorization Weakness

- Enforce authorization on the server for every sensitive endpoint; do not rely on hidden pages or client-side checks.
- Apply deny-by-default rules and verify the user's role and permissions on every request.
- For user-specific records, verify ownership or an explicit permission grant before returning data.
- Return only the minimum fields required for the requested operation.
- Add automated tests that verify a normal user cannot access administrator data or another user's records.

9.2 Strengthen Session Management

- Use cryptographically secure, unpredictable session identifiers with sufficient entropy.
- Regenerate the session identifier after login and privilege changes.
- Invalidate sessions on logout and when credentials or permissions change.
- Use Secure, HttpOnly and appropriate SameSite cookie attributes over HTTPS.
- Monitor suspicious session behavior and avoid exposing session tokens in logs or URLs.

9.3 Validate User-Controlled Parameters

- Validate parameter format and expected range on the server.
- Do not treat a supplied user ID as proof of authorization.
- Check object-level permissions for every read, update or delete operation.
- Return safe, consistent errors without exposing internal data.

9.4 Improve Authentication Protection

- Apply rate limiting and monitoring for repeated failed login attempts.
- Use secure password storage and appropriate password policy.
- Log authentication anomalies and alert on suspicious patterns.
- Continue manual and automated security testing within authorized scope.

9.5 Break the Attack Chain

The most important control is server-side authorization at the backend endpoint. If each request checks the caller's role and permissions before returning records, the path from a normal account to other users' information is interrupted. Secure session identifiers reduce the risk of session compromise, while object-level authorization and parameter validation reduce the chance that modified IDs can expose protected records.

10. Retesting Plan

19. Repeat the backend endpoint request as a non-admin user and confirm that administrator or other users' records are not returned.
20. Test the same endpoint as an authorized administrator to ensure legitimate access still works.
21. Use separate lab test accounts and verify that each account can access only its own records unless explicit permission is granted.
22. Collect multiple session identifiers in the lab and confirm that tokens are unpredictable and regenerated after login.
23. Repeat parameter-tampering tests and verify server-side ownership and permission checks.
24. Review logs to confirm denied requests are recorded without logging passwords or session tokens.
25. Document pass/fail results and attach sanitized evidence after remediation.

11. Conclusion

An authorized VAPT assessment of DVWA at Medium security level was carried out in an isolated virtual lab using Kali Linux, Firefox and Burp Suite Community Edition. The main observation was a possible backend authorization weakness: the restricted page denied access, while an inspected endpoint returned multiple user records, including administrator information. The report also records a potential session ID weakness and a parameter-tampering test, but neither session predictability nor IDOR was confirmed.

The assessment highlights that access control must be enforced by the server on every sensitive endpoint. Implementing object-level authorization, unpredictable session identifiers, careful parameter validation, authentication monitoring and independent API retesting can reduce the risk. The conclusions remain limited to the observations available in the presentation; no account takeover or administrative control was demonstrated.

Appendix A — Short Glossary

VAPT	Vulnerability Assessment and Penetration Testing.
Attack surface	The application entry points and interfaces that can be tested.
Authorization	The process that decides what an authenticated user is allowed to access.
Parameter tampering	Changing request values to test whether the application handles them securely.
IDOR	Insecure Direct Object Reference; a possible access-control flaw involving object identifiers.
Session ID	A token used by an application to associate requests with a logged-in session.
Burp Suite Repeater	A tool for modifying and resending HTTP requests during manual testing.

Prepared for DG Interns Hub — Cybersecurity Internship, Week 8.

Appendix B — Screenshots and Pictures from the Presentation

The images below are taken from the supplied Week 8 presentation and included as visual evidence. Refer to the relevant finding and testing procedure in the report for context.



Figure B1. Image extracted from slide 4 of the original Week 8 presentation.



Figure B2. Image extracted from slide 5 of the original Week 8 presentation.



Figure B3. Image extracted from slide 5 of the original Week 8 presentation.

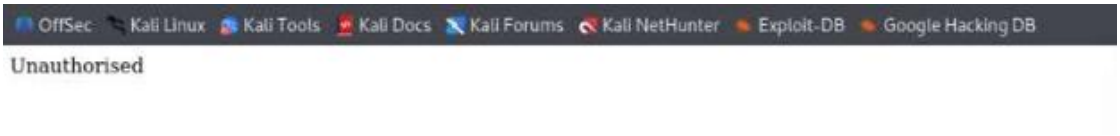


Figure B4. Image extracted from slide 6 of the original Week 8 presentation.



Figure B5. Image extracted from slide 6 of the original Week 8 presentation.

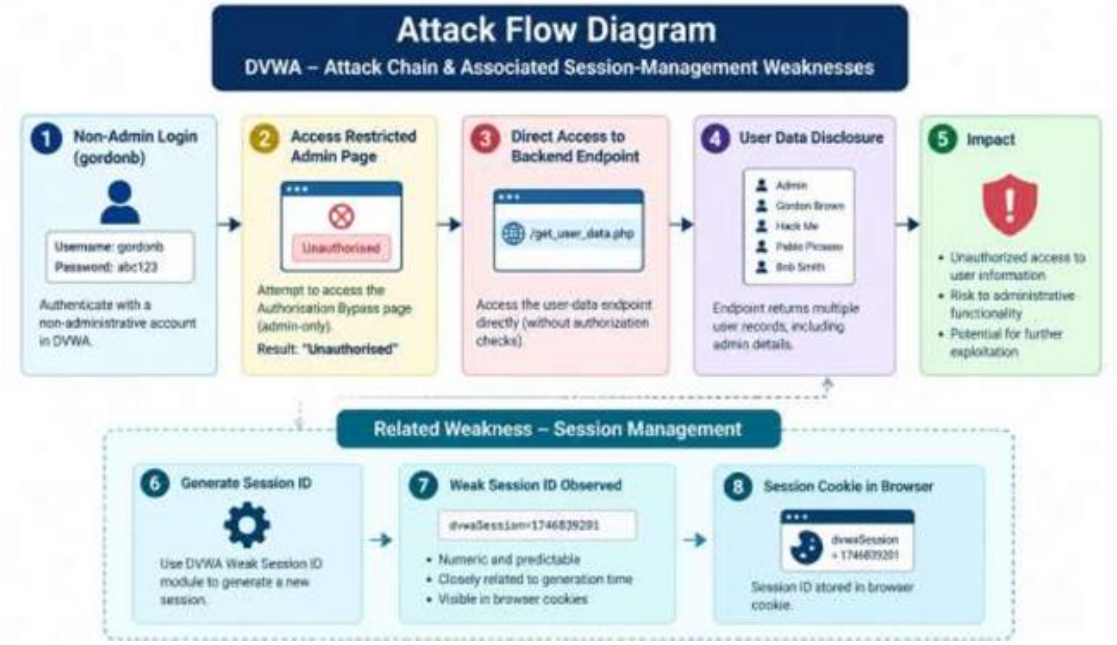


Figure B6. Image extracted from slide 7 of the original Week 8 presentation.

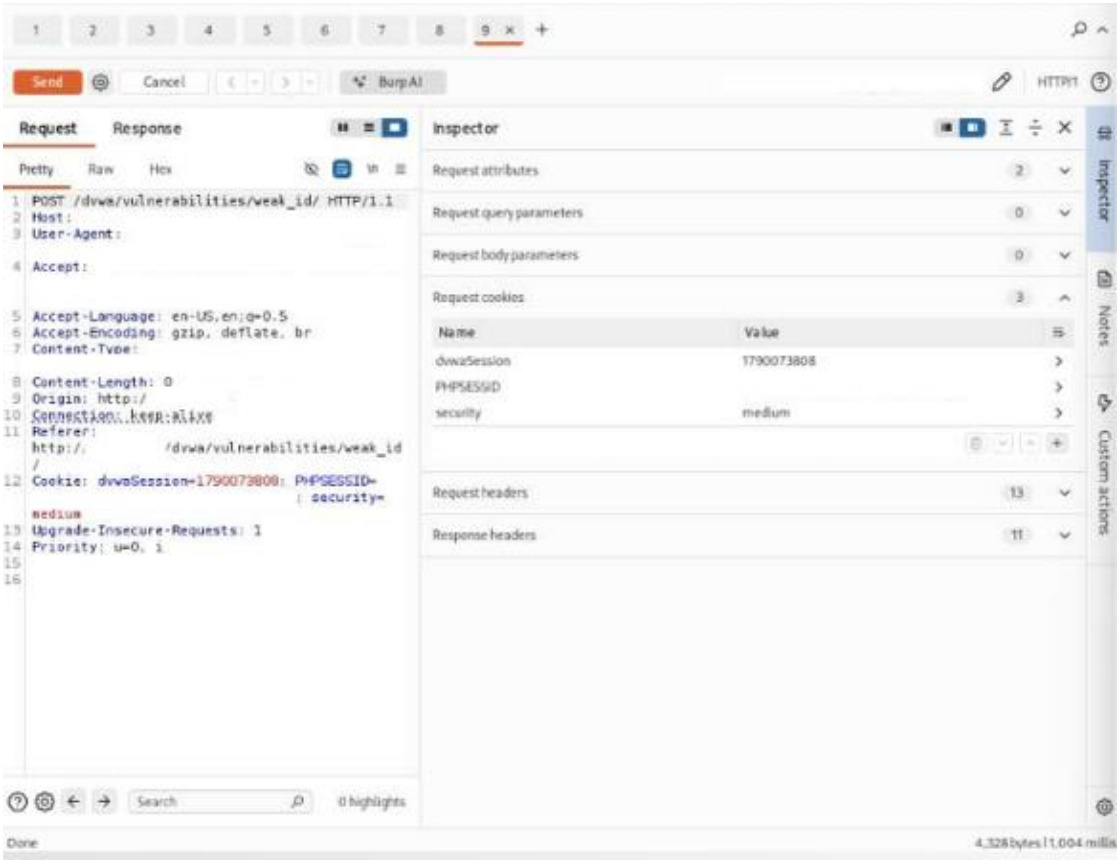


Figure B7. Image extracted from slide 8 of the original Week 8 presentation.